1.1 Создание схемы и тестовых данных

```sql
-- Создание отдельной схемы
CREATE SCHEMA IF NOT EXISTS injection_lab;
DROP TABLE IF EXISTS injection_lab.tasks CASCADE;
DROP TABLE IF EXISTS injection_lab.users CASCADE;
```

```sql
-- Таблица пользователей

CREATE TABLE injection_lab.users (
    user_id SERIAL PRIMARY KEY,
    username TEXT NOT NULL UNIQUE,
    full_name TEXT NOT NULL,
    role_name TEXT NOT NULL,
    email TEXT NOT NULL UNIQUE,
    password_plain TEXT NOT NULL
);

-- Таблица задач

CREATE TABLE injection_lab.tasks (
    task_id SERIAL PRIMARY KEY,
    title TEXT NOT NULL,
    description TEXT,
    status TEXT NOT NULL DEFAULT 'new',
    priority TEXT NOT NULL DEFAULT 'medium',
    assignee_username TEXT NOT NULL
        REFERENCES injection_lab.users(username),
    created_at TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP
);
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Messages

```
:03:53 PM     Started executing query at Line 2
              CREATE TABLE
:03:53 PM     Started executing query at Line 13
              CREATE TABLE
              Total execution time: 00:00:00.042
```

```sql

INSERT INTO injection_lab.users
    (username, full_name, role_name, email, password_plain)
VALUES
    ('alice', 'Alice Ivanova', 'employee', 'alice@corp.local', 'alice123'),
    ('bob', 'Bob Petrov', 'manager', 'bob@corp.local', 'bob123'),
    ('carol', 'Carol Sidorova', 'admin', 'carol@corp.local', 'carol123');

```

```sql

INSERT INTO injection_lab.tasks
    (title, description, status, priority, assignee_username)
VALUES
    ('Подготовить отчёт', 'Собрать метрики по проекту', 'new', 'high', 'alice'),
    ('Проверить права доступа', 'Аудит ролей PostgreSQL', 'in_progress', 'high', 'bob'),
    ('Обновить регламент', 'Документация по правилам доступа', 'new', 'medium', 'alice'),
    ('Закрыть инцидент', 'Проверить журналы событий', 'done', 'high', 'carol');

```

```sql

SELECT COUNT(*) AS users_count
FROM injection_lab.users;

SELECT COUNT(*) AS tasks_count
FROM injection_lab.tasks;
```

Problems Output Debug Console Terminal

Results Messages

	users_count
1	3

	tasks_count
1	4

2.1 Уязвимая аутентификация

```
SELECT user_id, username, role_name FROM injection_lab.users WHERE username = '' OR 1=1 --' AND password_plain = 'wrong_password';
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	user_id	username	role_name
1	1	alice	employee
2	2	bob	manager
3	3	carol	admin

2.2 Уязвимый поиск задач

```
SELECT task_id, title, status, priority
FROM injection_lab.tasks
WHERE status = 'new';
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	task_id	title	status	priority
1	1	Подготовить отчёт	new	high
2	3	Обновить регламент	new	medium

```
SELECT task_id, title, status, priority FROM injection_lab.tasks WHERE status = '' OR 1=1 --';
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	task_id	title	status	priority
1	1	Подготовить отчёт	new	high
2	2	Проверить права доступа	in_progress	high
3	3	Обновить регламент	new	medium
4	4	Закрыть инцидент	done	high

3.1 Перепишите аутентификацию безопасно

```
2  -- Подготовка безопасного запроса
3
4  PREPARE safe_login(text, text) AS
5  SELECT user_id, username, role_name
6  FROM injection_lab.users
7  WHERE username = $1
8    AND password_plain = $2;
```

Problems Output Debug Console Terminal Ports PostgreSQL

Messages

```
9:28:17 PM     Started executing query at Line 2
               PREPARE
               Total execution time: 00:00:00
```

```
1  --правильный логин и пароль
2  EXECUTE safe_login('alice', 'alice123');
```

Problems Output Debug Console Terminal Ports Postgre

Results Messages

	user_id	username	role_name
1	1	alice	employee

```
1  --вредоносный логин
2  EXECUTE safe_login(''' OR 1=1 --', 'anything');
```

Problems Output Debug Console Terminal Ports PostgreSQL Que

Results Messages

user_id	username	role_name

3.2 Защитите поиск задач

```
1
2   PREPARE safe_task_search(text) AS
3   SELECT task_id, title, status, priority
4   FROM injection_lab.tasks
5   WHERE status = $1;
```

Problems Output Debug Console Terminal Ports Po

Messages

```
9:31:21 PM      Started executing query at Line 2
                PREPARE
                Total execution time: 00:00:00
```

```
1   --обычный ввод
2   EXECUTE safe_task_search('new');
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	task_id	title	status	priority
1	1	Подготовить отчёт	new	high
2	3	Обновить регламент	new	medium

```
2   EXECUTE safe_task_search(''' OR 1=1 --');
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

task_id	title	status	priority

3.3 Защитите сортировку через белые списки

```
2  SELECT task_id, title, priority, created_at
3  FROM injection_lab.tasks
4  ORDER BY title ASC;
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	task_id	title	priority	created_at
1	4	Закрыть инцидент	high	2026-11-05 21:04:20.28821
2	3	Обновить регламент	medium	2026-11-05 21:04:20.28821
3	1	Подготовить отчёт	high	2026-11-05 21:04:20.28821
4	2	Проверить права доступа	high	2026-11-05 21:04:20.28821

```
1
2  SELECT task_id, title, priority, created_at
3  FROM injection_lab.tasks
4  ORDER BY priority DESC;
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	task_id	title	priority	created_at
1	3	Обновить регламент	medium	2026-11-05 21:04:20.28821
2	1	Подготовить отчёт	high	2026-11-05 21:04:20.28821
3	2	Проверить права доступа	high	2026-11-05 21:04:20.28821
4	4	Закрыть инцидент	high	2026-11-05 21:04:20.28821

4.1 Создайте ограниченную роль приложения

```
DROP ROLE IF EXISTS web_app_demo;

CREATE ROLE web_app_demo
LOGIN
PASSWORD 'demo_password_123';
```

```
-- Закрываем общий доступ к учебной схеме
REVOKE ALL ON SCHEMA injection_lab FROM PUBLIC;

-- Разрешаем роли пользоваться схемой
GRANT USAGE ON SCHEMA injection_lab TO web_app_demo;

-- Убираем общие права на таблицы схемы
REVOKE ALL ON ALL TABLES IN SCHEMA injection_lab FROM PUBLIC;

-- Разрешаем читать пользователей
GRANT SELECT ON injection_lab.users TO web_app_demo;

-- Разрешаем читать задачи
GRANT SELECT ON injection_lab.tasks TO web_app_demo;

-- Разрешаем изменять только статус задачи
GRANT UPDATE(status) ON injection_lab.tasks TO web_app_demo;
```

```
SELECT rolname, rolcanlogin, rolsuper
FROM pg_roles
WHERE rolname = 'web_app_demo';
```

Problems Output Debug Console Terminal Ports PostgreSQL

Results Messages

	rolname	rolcanlogin	rolsuper
1	web_app_demo	True	False

4.2

```sql
SELECT
    grantee,
    table_schema,
    table_name,
    privilege_type
FROM information_schema.role_table_grants
WHERE grantee = 'web_app_demo'
ORDER BY table_name, privilege_type;
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	grantee	table_schema	table_name	privilege_type
1	web_app_demo	injection_lab	tasks	SELECT
2	web_app_demo	injection_lab	users	SELECT

```sql
SELECT
    grantee,
    table_name,
    column_name,
    privilege_type
FROM information_schema.column_privileges
WHERE grantee = 'web_app_demo'
  AND table_schema = 'injection_lab'
  AND table_name = 'tasks'
  AND column_name = 'status'
  AND privilege_type = 'UPDATE';
```

Problems Output Debug Console Terminal Ports PostgreSQL Query Results

Results Messages

	grantee	table_name	column_name	privilege_type
1	web_app_demo	tasks	status	UPDATE

5.1

Фрагмент	Проблема	Опасный пример ввода	Исправление
Аутентификация	Логин и пароль напрямую вставляются в SQL-запрос. Возможен обход проверки пароля.	' OR 1=1 --	Параметризованный запрос с $1 и $2
Поиск задач	Значение статуса напрямую вставляется в условие WHERE. Пользователь может изменить условие и получить все задачи.	' OR 1=1 --	Параметризованный запрос с $1
Сортировка	Название столбца и направление сортировки добавляются в ORDER BY без ёпроверки.	title; DROP TABLE injection_lab.tasks; --	Белые списки разрешённых столбцов и направлений сортировки